

Northstar Labs Data Protection and Retention Policy

Version 1.0 – Internal Policy Document

Northstar Labs is committed to protecting personal data, customer information, and confidential business records in accordance with applicable UK data protection laws, including the UK General Data Protection Regulation (UK GDPR) and the Data Protection Act 2018. This policy defines how data is classified, stored, retained, protected, and securely disposed of across the organisation.

Document Owner	Data Protection Officer
Company	Northstar Labs
Version	1.0
Review Frequency	Annually
Classification	Internal Use
Effective Date	18 May 2026

1. GDPR Compliance

Northstar Labs processes personal data in accordance with the principles defined under the UK GDPR and the Data Protection Act 2018. The organisation ensures personal data is processed lawfully, fairly, transparently, and only for legitimate business purposes. Data subjects have the right to access, correct, restrict, or request deletion of their personal data where applicable under UK data protection legislation. Data protection considerations are incorporated into system design and software development practices through privacy-by-design principles.

2. Data Classification

Information handled by Northstar Labs is classified into the following categories: • Public – Information approved for public release. • Internal – Operational business information intended for internal use only. • Confidential – Sensitive commercial, customer, or employee information requiring controlled access. • Restricted – Highly sensitive information requiring enhanced protection measures. Employees must ensure data is appropriately labelled, stored, and protected based on its classification level.

3. Data Retention Periods

Personal data and business records must only be retained for as long as required to fulfil legal, contractual, operational, or regulatory obligations. Standard retention periods include: • Customer contracts and commercial records: 7 years • Employee records: 6 years after employment ends • Security logs: 12 months • Backup archives: 90 days • Recruitment data for unsuccessful candidates: 12 months Data exceeding defined retention periods must be securely deleted or anonymised.

4. Secure Deletion

Northstar Labs uses secure deletion procedures to ensure confidential and personal data cannot be recovered after disposal. Electronic records must be permanently deleted using approved deletion or wiping methods. Physical documents containing sensitive information must be shredded or disposed of using approved confidential waste services. Devices containing company or customer data must undergo secure wiping procedures before disposal or reuse.

5. Backup Handling

Regular backups are performed to support business continuity and disaster recovery requirements. Backups containing confidential or personal data must be encrypted both in transit and at rest. Access to backup systems is restricted to authorised personnel only. Backup restoration processes are tested periodically to verify data integrity and recovery capability. Backup retention schedules must align with operational and regulatory requirements.

6. Data Storage Regions

Northstar Labs primarily stores customer and company data within the United Kingdom and approved regions within the European Economic Area (EEA). Where third-party cloud providers are used, the organisation ensures appropriate contractual, technical, and organisational safeguards are implemented. Cross-border transfers of personal data outside the UK or EEA must comply with applicable data transfer requirements under UK GDPR.

7. Personally Identifiable Information (PII) Handling

Personally identifiable information (PII) must only be accessed by authorised individuals with a legitimate business requirement. PII must not be shared externally unless authorised, encrypted where appropriate, and protected against unauthorised access or disclosure. Employees must immediately report any suspected data breach, accidental disclosure, or unauthorised access involving personal information. The organisation maintains incident response procedures to support regulatory reporting obligations and customer notification requirements where necessary.